

제1조(목적)

문서명: 개인정보 및 정보보호 통제 기준

소관: 가상 준법감시위원회 | 시행일: 2026-01-01

GRC Compliance Reviewer 테스트용 기준 문서

이 기준은 개인정보와 중요정보를 안전하게 보호하기 위하여 조직이 준수해야 할 최소 통제 요건을 정함을 목적으로 한다.

이 문서는 실제 법률 자문이나 회사 규정이 아닌 소프트웨어 기능 검증용 가상 문서이다.

제2조(접근권한 관리)

정보시스템 접근권한은 최소권한 원칙에 따라 업무상 필요한 범위로만 부여하고, 부서장과 정보보호책임자의 사전 승인을 받아야 한다.

접근권한은 분기마다 검토하며 퇴직, 전보 또는 업무 종료 사실을 확인한 때부터 24시간 이내에 회수해야 한다.

제3조(다중인증)

외부 네트워크에서 내부 시스템에 접속하는 모든 사용자와 관리자 권한 사용자는 다중인증을 적용해야 한다.

비밀번호만을 사용한 외부 접속은 허용하지 않는다.

제3조의2(특권계정)

특권계정은 개인별로 발급하고 공동 사용을 금지한다. 비밀번호는 60일마다 변경하며 사용 내역은 별도 감사기록으로 남겨야 한다.

제4조(암호화)

저장되는 개인정보와 중요정보는 AES-256 이상 수준으로 암호화해야 한다.

전송 구간은 TLS 1.2 이상을 사용해야 하며 TLS 1.0과 TLS 1.1은 예외 없이 금지한다.

제5조(보안사고 대응)

개인정보 유출 또는 침해 정황을 발견한 임직원은 즉시 정보보호책임자에게 보고해야 한다.

사고대응팀은 최초 보고 후 4시간 이내에 초기 영향평가를 완료하고 관계 법령에서 정한 기한 안에 감독기관과 정보주체 통지 여부를 결정해야 한다.

제6조(보존과 파기)

개인정보는 수집 목적이 달성되거나 보존기간이 끝난 날부터 30일 이내에 복구할 수 없는 방법으로 파기해야 한다.

법령상 보존 의무로 파기를 유예할 때에는 근거, 대상, 책임자와 종료일을 문서로 기록해야 한다.

제7조(수탁자 관리)

개인정보 처리 업무를 외부 업체에 맡기기 전에 보안수준 평가와 개인정보 처리위탁 계약 체결을 완료해야 한다.

수탁자의 통제 이행 여부는 매년 한 차례 이상 점검하고 발견된 미흡사항에 대한 개선 완료를 확인해야 한다.

제8조(백업과 복구)

중요정보는 매일 한 차례 이상 백업하고 운영 환경과 분리된 위치에 보관해야 한다.

복구시험은 분기마다 실시하며 목표복구시간은 4시간, 목표복구시점은 24시간 이내로 유지해야 한다.

제9조(감사로그)

관리자 활동, 개인정보 조회, 다운로드와 권한 변경 기록은 최소 1년간 보관해야 한다.

감사로그는 위변조를 방지하고 담당자가 매월 이상징후를 검토한 뒤 결과를 기록해야 한다.

제10조(교육)

모든 임직원은 연 1회 이상 개인정보 및 정보보호 교육을 이수해야 한다.

신규 입사자와 권한이 확대된 담당자는 시스템 접근권한을 부여받기 전에 직무별 보안교육을 이수해야 한다.

별표 1. 핵심 통제 시험 기준

통제영역	필수 기준	기대 상태	예상 심각도
접근권한	분기 검토 및 24시간 내 회수	충족	High
전송암호화	TLS 1.2 이상	충족	Critical
보존·파기	목적 달성 후 30일 내 파기	충족	High
백업·복구	매일 백업, 분기 복구시험	충족	High

시험 안내: 문서 간 차이는 의도적으로 설계되었으며 실제 조직의 통제 수준을 나타내지 않습니다.